Tasks.md Unauthenticated Path Traversal to RCE

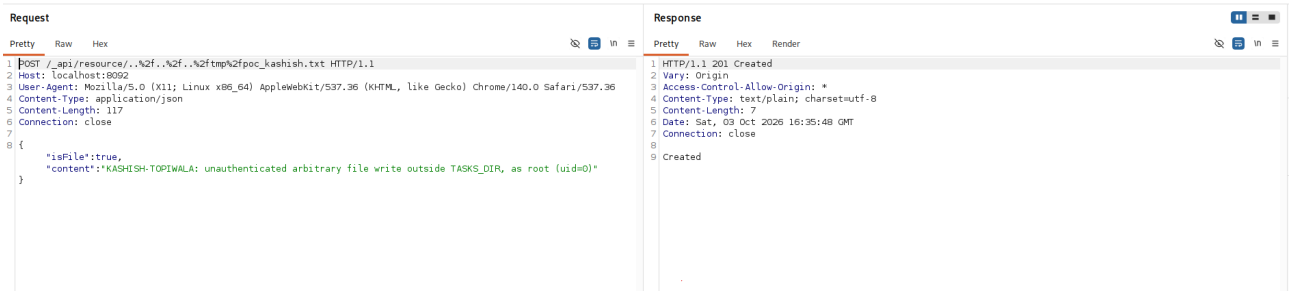
Researcher	Kashish Topiwala
Product	Tasks.md (BaldissaraMatheus/Tasks.md)
Affected	Tasks.md (current and earlier)
CWE	CWE-22 Improper Limitation of a Pathname to a Restricted Directory
CVSS 3.1	9.8 Critical (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)

Summary

Tasks.md is a self-hosted markdown kanban board. Its backend builds a filesystem path by joining a user-controlled URL segment onto the data directory TASKS_DIR with no sanitization. A request with ../ sequences escapes TASKS_DIR and reaches any file on the container. The official image runs the server as root with TASKS_DIR=/tasks, so an attacker overwrites the application entry point and runs code as root.

Steps to reproduce

1 Send a POST to /_api/resource/ with a path segment that contains ../ sequences, and the file content in the request body. The server writes the body to the traversed path.



2 Confirm the file was written outside TASKS_DIR, owned by root.



3 Overwrite the application entry point (for example /api/server.js) and let the container restart to run code as root.

Impact

- An unauthenticated remote attacker writes, reads, and recursively deletes any file on the container.
- The official image runs as root, so the attacker runs code as root.
- Overwriting the application file gives a persistent remote shell as root.

Remediation

- Reject path segments that contain ../ or are absolute.
- Resolve the final path and verify it stays inside TASKS_DIR before any read, write, or delete.
- Run the container as a non-root user.

References

- https://github.com/BaldissaraMatheus/Tasks.md/blob/main/backend/server.js
- https://cwe.mitre.org/data/definitions/22.html